

TS ACADEMY

CYBERSECURITY CAPSTONE PROJECT

TITLE: FROM VULNERABILITY TO COMPLIANCE; SECURING LEGACY SYSTEMS AT APEX HEALTHCARE SOLUTIONS

Student name:	Utibe Anthony Akpan
Email Address:	akpanutibe342@gmail.com
Group Number:	239
Group List:	Ogbu Chinyem Steven, Zainab Ayoka Muritala Zorian Pere Joel, Jegede Samuel Oluwaferanmi Shamimi Daniella Iorliam, Inegite Patrick Goodness Utibe Anthony Akpan, Sadiq abdurahaman, Ugwoke Samuel Ekenedilichukwu

EXECUTIVE SUMMARY

As part of Apex Healthcare Solutions' ongoing commitment to protecting customer data, a vulnerability assessment was carried out on two of the organization's systems — Kioptrix and Metasploitable2. This assessment identified several security weaknesses that, if left unaddressed, could allow attackers to gain unauthorized access to our network and compromise sensitive customer information.

The vulnerabilities identified ranged from outdated software with known weaknesses, to misconfigured services that could be exploited remotely, to weak encryption standards that could expose data in transit. Left unmitigated, these risks could result in data breaches, financial loss, regulatory non-compliance, and significant damage to Apex Healthcare Solutions' reputation and customer trust.

To address these risks, this report recommends a combination of technical security controls — including regular software patching, stricter access restrictions, and stronger encryption standards — along with supporting governance policies to ensure these protections are maintained consistently going forward. Each vulnerability has been rated by likelihood and potential impact to help prioritize remediation efforts.

Implementing these recommendations will significantly strengthen Apex Healthcare Solutions' security posture, reduce the risk of a data breach, and reinforce the organization's commitment to safeguarding customer data

VULNERABILITY FINDINGS

The following vulnerabilities were discovered during vulnerability scanning of the Kioptrix. **1.**

Samba trans2open Buffer Overflow (CVE-2003-0201)

Field	Detail
Vulnerability Name	Samba trans2open Buffer Overflow
Affected Service	SMB — port 139

Description:

CVE-2003-0201 is a buffer overflow vulnerability found in the `call_trans2open` function within the `trans2.c` source file of the Samba software suite. It affects Samba versions 2.2.x before 2.2.8a, 2.0.10 and earlier 2.0.x versions, and Samba-TNG before 0.3.2. The flaw allows remote attackers to execute arbitrary code on the target system.

In plain terms, when certain crafted SMB requests are sent to a vulnerable Samba server, they trigger unsafe memory handling — causing the application to write data beyond its allocated memory buffer. This overflow can be weaponized to inject and run malicious code with the privileges of the Samba process, which is typically root on Linux systems.

Potential Attacker Goal:

The attacker's primary goal with this vulnerability is **Remote Code Execution (RCE)** — specifically gaining a **root-level shell** on the target machine without any authentication required.

By exploiting the trans2open buffer overflow via tools like Metasploit, an attacker can successfully open reverse shell sessions on the target system and obtain full root access.

Once root access is achieved, the attacker can:

- Read, modify, or delete any files on the system
- Create backdoor accounts
- Pivot to other machines on the same network
- Exfiltrate sensitive data

2. Apache mod_ssl Buffer Overflow (OpenFuck) (CVE-2002-0082)

Field	Detail
Vulnerability Name	Apache mod_ssl Buffer Overflow (OpenFuck)
Affected Service	HTTPS — port 443

Description:

CVE-2002-0082 is a buffer overflow vulnerability found in the DBM and SHM session cache code of **mod_ssl** before version 2.8.7-1.3.23, and **Apache-SSL** before version 1.3.22+1.46. The

flaw exists in the `i2d_SSL_SESSION` function, which does not properly initialize memory. This allows remote attackers to execute arbitrary code by submitting a large client certificate signed by a trusted Certificate Authority (CA), which produces an oversized serialized session.

In plain terms: when SSL session caching is enabled, `mod_ssl` serializes SSL session variables into a fixed-size buffer for storage. The variables were stored in a buffer of fixed size without proper boundary checks. An attacker can craft an oversized client certificate that, when processed, overflows that buffer — allowing them to inject and execute malicious code on the server. This vulnerability is highly exploitable since it requires low complexity and no prior authentication.

Potential Attacker Goal:

The attacker's primary goal is **Remote Code Execution (RCE)** — gaining an unauthorized shell on the server, typically with elevated privileges. An attacker who successfully exploits this can:

- Gain a root-level or web server process-level shell on the target
- Read sensitive files including configuration files, credentials, and private SSL keys
- Pivot deeper into the internal network
- Deface or manipulate web content served by the Apache server
- Plant persistent backdoors for long-term unauthorized access

3. Apache HTTP Denial of Service (CVE-2002-0392)

Field	Detail
Vulnerability Name	Apache HTTP Denial of Service
Affected Service	HTTP — port 80

Description

It is a severe buffer overflow and denial-of-service (DoS) vulnerability in the [Apache HTTP Server](#) that affects the way the software processes chunked transfer encoding. The server fails to properly sanitize the length of data provided in chunked HTTP requests, passing an excessively large length value, which wraps the value into a negative number, and this incorrect size calculation allows remote attackers to trigger a buffer overflow or a signal race condition. This can result in a Denial of Service (DoS) or the execution of arbitrary code with the privileges of the web server user.

Potential Attacker Goal

A remote, unauthenticated attacker could send a specially crafted chunked HTTP request to:

- Cause a denial of service (crash the Apache process/server)
- Possibly execute arbitrary code with the privileges of the web server process.

The following vulnerabilities were discovered during vulnerability scanning of the Metasploitable2

1. vsftpd 2.3.4 Backdoor Command Execution (CVE-2011-2523)

Field	Detail
Vulnerability Name	vsftpd 2.3.4 Backdoor Command Execution
Affected Service	FTP — port 21

Description

Between June 30 and July 1, 2011, attackers secretly inserted a backdoor into the official vsftpd 2.3.4 download package (vsftpd-2.3.4.tar.gz). This tampered version was available for a few days before it was discovered and removed on July 3, 2011.

The backdoor works in a simple but dangerous way: if someone logs into the FTP server using a username that contains a smiley face (":)"), the compromised software secretly opens a hidden shell on port 6200. Anyone who connects to that port gains direct, unauthorized access to the system — no password required.

This flaw falls under CWE-78 (OS Command Injection), since it ultimately lets an attacker run commands on the system as if they were logged in directly. Given how easily and reliably it can be triggered, it's rated critical, with a CVSS score of 9.8.

Potential Attacker Goal

Full unauthorized remote access to the host system — the attacker connects to the FTP service, sends the trigger string in the username field, then connects to the resulting shell on port 6200/tcp to gain root-level command execution, enabling complete system compromise and further malicious activity such as data theft, lateral movement across the network, and establishing persistence for long-term access.

2. distccd Remote Command Execution (CVE-2004-2687)

Field	Detail
Vulnerability Name	distccd Remote Command Execution
Affected Service	distccd — TCP port 3632

Description

distccd Remote Command Execution is a critical remote code execution (RCE) vulnerability affecting the distccd (Distributed Compiler Daemon) service, versions up to 3.1, as well as Apple Xcode versions prior to 2.1. It is tracked as CVE-2004-2687 and carries a CVSS v2 score of 9.3, making it critical. By default, the distccd service listens on TCP port 3632. If the server is not configured to restrict access or restrict which commands it processes, the daemon will accept compilation jobs from any unauthenticated client and execute them with the privileges of the user running the daemon. **Potential Attacker Goal**

The attacker's goal is to submit a malicious compilation job containing arbitrary shell commands to the exposed distccd service. Since the daemon executes jobs without authentication, this grants immediate remote code execution with the privileges of the distccd process. From there, the attacker can escalate privileges, establish persistence, exfiltrate sensitive organizational data, or deploy additional malware such as ransomware — resulting in full compromise of the host. **3.**

Postfix SMTP Weak TLS Configuration (CVE-2015-4000 (Logjam))

Field	Detail
Vulnerability Name	Postfix SMTP Weak TLS Configuration
Affected Service	SMTP – Port 25

Description

The Postfix SMTP service was found to support weak 512-bit Diffie-Hellman (DH) key exchanges during SSL/TLS negotiation. This vulnerability, known as Logjam, allows an attacker positioned as a man-in-the-middle to force a downgrade of the encryption to export-grade cryptography. Once downgraded, the weak DH parameters can be feasibly broken using precomputation techniques, allowing the attacker to decrypt or manipulate what should be secure, encrypted communications.

Potential Attacker Goal

An attacker could exploit the server's support for weak 512-bit DH key exchanges to downgrade the encryption strength of SSL/TLS sessions. This would allow them to:

Intercept and decrypt sensitive data, such as login credentials and confidential communications

Inject malicious content into what appears to be an encrypted, trusted session

Undermine the confidentiality and integrity guarantees of SSL/TLS on affected connections

RISK ASSESSMENT

Vulnerability	Likelihood	Impact	Risk Rating
Samba trans2open Buffer Overflow	High	High	High
Apache mod_ssl Buffer Overflow	High	High	High
(OpenFuck)			
Apache HTTP Denial of Service	High	Medium	High
vsftpd 2.3.4 Backdoor Command Execution	High	High	High

distccd Remote Command Execution	High	High	High
Postfix SMTP Weak TLS Configuration	Medium	Medium	Medium

SECURITY CONTROL RECOMMENDATION

Vulnerability	Recommended control
Samba trans2 Buffer Overflow	Patch Management Process

Explanation:

The Samba trans2 buffer overflow vulnerability (CVE-2003-0201) allows an attacker to send specially crafted requests that overflow the buffer, potentially leading to remote code execution. Applying vendor-released patches through a structured patch management process closes this vulnerability by correcting the flawed code, reducing the risk of unauthorized remote access and system compromise.

Vulnerability	Recommended control
Apache mod_ssl Buffer Overflow (OpenFuck)	Firewall Access Restriction

Explanation:

The Apache mod_ssl buffer overflow (OpenFuck) vulnerability (CVE-2002-0082) allows an attacker to send an oversized client certificate that overflows the buffer, potentially leading to remote code execution. Implementing firewall access restrictions reduces this risk by limiting which IP addresses or networks are allowed to reach the SSL service, preventing untrusted or external sources from ever reaching the vulnerable service to deliver the malicious certificate.

Vulnerability	Recommended control
Apache HTTP Denial of Service	Intrusion Prevention System (IPS)

Explanation:

The Apache HTTP Denial of Service vulnerability (CVE-2002-0392) allows an attacker to send malformed HTTP requests that crash the server or exhaust its resources, resulting in denial of service. Implementing an Intrusion Prevention System reduces this risk by detecting and blocking malicious or malformed traffic patterns in real time, before the requests ever reach the vulnerable Apache service.

Vulnerability	Recommended control
---------------	---------------------

vsftpd 2.3.4 Backdoor Command Execution	Application Whitelisting
---	--------------------------

Explanation:

The vsftpd 2.3.4 Backdoor Command Execution vulnerability (CVE-2011-2523) is a malicious backdoor planted in a compromised version of the software, allowing an attacker to gain a remote command shell on the system. Implementing application whitelisting reduces this risk by ensuring only verified, trusted software versions are allowed to run on the system, preventing compromised or backdoored software from being installed or executed in the first place.

Vulnerability	Recommended control
distccd Remote Command Execution	Access Control List (ACL)

Explanation:

The distccd remote command execution vulnerability (CVE-2004-2687) occurs because the distcc daemon has no built-in authentication and accepts connections from any host able to reach it, allowing an attacker to execute arbitrary commands on the system. Implementing an Access Control List reduces this risk by restricting which hosts or IP addresses are permitted to connect to the distccd service, addressing the root cause — the lack of authentication — by controlling access at the network level instead.

Vulnerability	Recommended control
Postfix SMTP Weak TLS Configuration	Cryptographic Configuration Hardening

Explanation:

The Postfix SMTP weak TLS vulnerability (CVE-2015-4000) allows an attacker to force a connection to downgrade to weak, export-grade encryption, making it possible to intercept and decrypt supposedly secure traffic. Implementing cryptographic configuration hardening reduces this risk by disabling weak cipher suites and enforcing strong, modern encryption standards, preventing the connection from ever being downgraded to an exploitable level.

POLICIES RECOMMENDATION

1. Patch Management Policy

Purpose:

The purpose of this policy is to ensure that all known vulnerabilities in our systems are identified, tested, and patched in a timely manner, reducing the window of opportunity attackers have to exploit them.

Why needed:

During our assessment, a remote command execution vulnerability was discovered in our system. If left unpatched, this could allow an attacker to gain unauthorized access to the network and potentially reach customer data — which we, as a healthcare solutions provider, are responsible for protecting. A breach of this nature would not only compromise sensitive data but also damage the organization's reputation and trust with our clients.

Vulnerability addressed:

This policy directly addresses the risk of remote command execution vulnerabilities by ensuring they are identified and patched before an attacker can exploit them.

2. Access Control Policy**Purpose:**

The purpose of this policy is to ensure that only authorized hosts, users, or systems are permitted to access sensitive services, reducing exposure to unauthorized connections.

Why needed:

A vulnerability was discovered that allowed unrestricted access to a service with no built-in authentication, which could give an attacker a path to reach customer data and damage our organization's reputation.

Vulnerability addressed: This policy addresses the distccd Remote Command Execution vulnerability (CVE-2004-2687) by restricting connections to only trusted, verified hosts.

3. Vulnerability Management Policy**Purpose:**

The purpose of this policy is to establish a continuous process for identifying, assessing, and remediating vulnerabilities across the organization's systems before they can be exploited.

Why needed:

Our assessment discovered multiple vulnerabilities across our systems — including remote code execution and weak encryption flaws — that could allow attackers to compromise our systems and access customer data, damaging the organization's reputation and trust. **Vulnerability addressed:**

This policy addresses the risk of undiscovered or unmanaged vulnerabilities across the organization by ensuring systems are regularly scanned, assessed, and remediated — covering all vulnerabilities identified in this assessment, including the Samba, Apache, vsftpd, distccd, and Postfix flaws.

4. Secure Configuration Management Policy

Purpose:

The purpose of this policy is to ensure that all software installed on organizational systems is obtained from verified, trusted sources and configured securely before deployment.

Why needed:

Our assessment discovered a vulnerability where a compromised version of software (vsftpd 2.3.4) contained a hidden backdoor, which could allow an attacker to gain unauthorized remote access to our systems and potentially reach customer data — damaging the organization's reputation.

Vulnerability addressed:

This policy addresses the vsftpd 2.3.4 Backdoor Command Execution vulnerability (CVE20112523) by ensuring software is only sourced and installed from verified vendors, preventing compromised or backdoored versions from being deployed on organizational systems.

CONCLUSION

This assessment has highlighted several vulnerabilities within Apex Healthcare Solutions' systems that pose real risks to the confidentiality and integrity of customer data. While these findings may seem concerning, they also represent an opportunity — addressing them proactively puts the organization ahead of potential threats rather than reacting after a breach occurs.

By implementing the recommended security controls and governance policies outlined in this report, Apex Healthcare Solutions can significantly reduce its exposure to these risks and strengthen its overall security posture. Continued investment in vulnerability management, staff awareness, and regular security assessments will be essential to maintaining this posture as new threats emerge.

Ultimately, protecting customer data is not a one-time effort but an ongoing responsibility. This report provides a clear starting point for Apex Healthcare Solutions to take meaningful action toward a more secure and resilient environment.